

Relatório de Auditoria Lynis: Linha de Base, Remediação e Resultado Final

Metadados do Projeto

Data: 24 de setembro de 2026

Ambiente: Ubuntu Server 24.04 LTS (Kernel 6.8.0, Bare-Metal, Headless)

Ferramenta Base: Lynis 3.0.9 (CISOfy)

1. Sumário Executivo

Este relatório documenta o processo de auditoria de segurança da informação e endurecimento (*hardening*) executado no servidor residencial denominado **plmnsrv**. O principal objetivo técnico do projeto consistiu na redução contínua da superfície de ataque operacional em um servidor bare-metal headless de sistema operacional **Ubuntu Server 24.04 LTS**, mantendo como premissa mandatória a disponibilidade ininterrupta de todos os serviços de rede e aplicação em produção (Nextcloud via pilha LAMP, Cockpit, Jellyfin, Pi-Hole, Caddy Reverse Proxy e OpenSSH).

A intervenção técnica resultou na evolução do indicador geral de segurança (*Hardening Index*) de **75** para **80** pontos, representando um incremento relativo de **+6,7%** na postura defensiva do ativo. O único alerta crítico reportado (*Warning*) foi totalmente mitigado, reduzindo a métrica de **1** para **0**. O volume total de recomendações pendentes (*Suggestions*) declinou de **40** para **33**, contemplando uma expansão de três novos vetores de teste validados no segundo ciclo. O marco operacional primordial foi atingido de forma estrita: registrou-se **zero interrupção** ou instabilidade funcional nos serviços de aplicação, mantendo a integridade operacional das rotas de comunicação externa e interna.

2. Metodologia de Execução

A avaliação da postura de segurança utilizou o software de auditoria e conformidade **Lynis 3.0.9**, executado em modo de inspeção profunda do sistema local – modo privilegiado (`sudo lynis audit system`). O ciclo metodológico contemplou a cobertura transversal das camadas de autenticação, módulos de kernel, configuração de daemons de rede, integridade de arquivos e auditoria contínua de processos.

Com a finalidade de resguardar a disponibilidade contínua dos serviços locais, todos os apontamentos identificados na auditoria de linha de base foram catalogados e distribuídos em três matrizes de decisão operacional:

- Categoria A — Remediável sem Impacto:** Ações passíveis de aplicação imediata sem interrupção de processos, sem necessidade de reinicialização do sistema e sem bloqueio das portas de serviço.
- Categoria B — Aplicação em Boot Programado:** Modificações estruturais aplicadas em arquivos de configuração estática cuja ativação efetiva ocorre durante o ciclo normal de reboot do equipamento, não induzindo parada de produção imediata.
- Categoria C — Não Aplicável por Risco de Ruptura Operacional:** Controles cuja implementação degradaria funcionalidades mandatórias (Nextcloud, Jellyfin, Performance Co-Pilot) ou acarretaria risco desproporcional de bloqueio de acesso (*lockout*) em nó bare-metal headless.

Como protocolo de segurança contra falhas durante a execução, todos os arquivos de configuração receberam cópias de segurança com timestamp prévio (*.bak*). Adicionalmente, verificações sintáticas obrigatórias (como `sshd -t`) foram

atreladas aos fluxos de recarregamento suave de daemons (*systemctl reload*), enquanto sessões administrativas OpenSSH paralelas foram mantidas abertas para mitigar riscos de perda de conectividade.

3. Comparativo de Indicadores: Antes vs. Depois

A tabela abaixo sintetiza os resultados quantitativos obtidos na auditoria inicial de linha de base confrontados com o ciclo de re-auditoria executado imediatamente após a aplicação das remediações autorizadas.

Métrica de Auditoria	Scan 1 (Linha de Base)	Scan 2 (Pós-Remediação)	Variação Líquida
Hardening Index (Índice Geral)	75	80	+5 (+6,7%)
Alertas Críticos (Warnings)	1	0	-1 (-100%)
Recomendações (Suggestions)	40	33	-7 (-17,5%)
Total de Testes Executados	274	277	+3 (+1,1%)

4. Controles Remediados e Validação Técnica

As intervenções realizadas focaram na eliminação de vetores comuns de exploração, fortalecimento dos mecanismos de autenticação local, validação de integridade estática e adequação das configurações de daemons expostos.

Controle Lynis	Vetor / Componente	Ação Técnica Executada	Resultado Operacional
MAIL-8818 / MAIL-8820	Postfix MTA	Ocultação de banner detalhado (smtpd_banner) e desativação do comando VRFY. Recarga suave aplicada.	Alerta crítico (Warning) eliminado; enumeração de usuários bloqueada.
AUTH-9262	Módulo PAM	Implementação da biblioteca libpam-pwquality com requisitos mínimos de complexidade e tamanho de senha.	Requisitos estritos de entropia aplicados a novas credenciais.
AUTH-9286	Login Definitions	Ajuste de envelhecimento de senhas no login.defs e aplicação de 'chage' exclusivo à conta do operador humano.	Ciclo de vida de senhas padronizado sem impactar contas de daemons.

KRNL-5820	Core Dumps	Bloqueio de despejos de memória de processos via <code>limits.conf</code> (* hard core 0) e <code>fs.suid_dumpable</code> .	Mitigação de vazamento de credenciais via despejo de memória.
SSH-7408	OpenSSH Daemon	Ajuste dos parâmetros <code>ClientAliveCountMax</code> (2) e <code>MaxSessions</code> (2) através de drop-in file em <code>sshd_config.d</code> .	Limitação de sessões ociosas mantendo conexão administrativa estável.
ACCT-9630	Auditd Engine	Criação de regras em <code>audit/rules.d</code> para rastreamento de alterações em contas (<code>/etc/passwd</code> , <code>shadow</code>) e <code>sudoers</code> .	Trilha de auditoria em conformidade com requisitos de integridade.
FINT-4350	AIDE Engine	Instalação do utilitário AIDE, geração de base de dados estática inicial e agendamento de checagem diária.	Mecanismo autônomo de verificação de adulteração de binários.

5. Hardening de Parâmetros de Kernel (KRNL-6000)

O endurecimento dos parâmetros em tempo de execução do kernel foi aplicado mediante a criação do arquivo estruturado `/etc/sysctl.d/99-hardening.conf`. A ativação dos parâmetros ocorreu de forma dinâmica por intermédio do utilitário `sysctl --system`, dispensando a reinicialização do hardware e mantendo todos os sockets de rede e discos em funcionamento contínuo.

Os seguintes parâmetros foram consolidados na configuração permanente do ambiente:

- **dev.tty.ldisc_autoload = 0:** Previne o carregamento automático e arbitrário de disciplinas de linha TTY vulneráveis.
- **fs.protected_fifos = 2:** Impede que dados sejam gravados em FIFOs de terceiros dentro de diretórios compartilhados temporários.
- **fs.suid_dumpable = 0:** Bloqueia a geração de core dumps originados de binários com o bit SUID ativo.
- **kernel.core_uses_pid = 1:** Força a concatenação do identificador de processo (PID) ao nome dos arquivos de despejo de memória.
- **kernel.perf_event_paranoid = 3:** Restringe severamente o acesso de usuários não privilegiados a subsistemas de rastreamento de desempenho.
- **kernel.sysrq = 0:** Desativa integralmente a combinação de teclas mágicas de controle de baixo nível do kernel.
- **kernel.unprivileged_bpf_disabled = 1:** Restringe o carregamento e execução de programas eBPF exclusivamente ao superusuário.
- **net.core.bpf_jit_harden = 2:** Ativa a proteção avançada de blinding constante contra ataques JIT-spraying na pilha de rede.
- **net.ipv4.conf.all.log_martians = 1:** Habilita o registro detalhado em log de pacotes com endereços impossíveis ou forjados.

- **net.ipv4.conf.default.accept_source_route = 0:** Desativa a aceitação de roteamento direto pela origem em interfaces de rede padrão.

6. Matriz de Priorização das Recomendações Pendentes

As 33 sugestões remanescentes apontadas pelo motor de auditoria foram analisadas sob o prisma da criticidade de segurança versus a complexidade de implementação no ambiente, dividindo-se em três horizontes de atendimento.

6.1 Prioridade Alta — Ações Rápidas sem Impacto

Ações de saneamento imediato, sem dependências de infraestrutura complexa e totalmente seguras para a pilha de aplicações:

- **BANN-7126 e BANN-7130:** Implantação de avisos legais de uso restrito em */etc/issue* e */etc/issue.net* para inibir divulgação passiva da versão da distribuição antes da autenticação.
- **NAME-4402:** Normalização do arquivo */etc/hosts* através da remoção de entradas duplicadas e garantia do mapeamento do host **plmnsrv**.
- **FINT-4402:** Configuração dos algoritmos de hash SHA-256 e SHA-512 na rotina de cálculo de somas de verificação do utilitário AIDE.
- **MALW-3286:** Padronização da rotina de atualização autônoma das assinaturas antivírus da ferramenta ClamAV via freshclam.
- **PKGS-7346:** Remoção controlada (purge) de aproximadamente 42 bibliotecas e pacotes declarados órfãos pelo gerenciador APT.
- **PKGS-7410:** Limpeza de versões residuais antigas de imagens do kernel via *apt autoremove*, conservando duas imagens funcionais por segurança.

6.2 Prioridade Média — Decisões com Gestão de Risco

Itens técnicos recomendáveis, mas que exigem janela de alteração controlada ou validação de reboot planejado:

- **SSH-7408 (Alteração de Porta):** Requer liberação antecipada no firewall UFW, alteração em *sshd_config.d* e teste concorrente via terminal secundário para evitar *lockout* administrativo do nó headless.
- **BOOT-5122 (Proteção de GRUB):** Inserção de senha criptografada via PBKDF2 no carregador de inicialização. Exige presença física ou console KVM em caso de esquecimento da credencial.
- **DEB-0280 e DEB-0810:** Instalação das bibliotecas complementares *libpam-tmpdir* (isolamento de diretórios temporários de usuários) e *apt-listbugs*.
- **NETW-3200:** Bloqueio definitivo de módulos de protocolos de transporte legados ou desnecessários (DCCP, SCTP, RDS, TIPC) via modprobe, com efetivação no boot.
- **ACCT-9626:** Habilitação e retenção histórica de métricas de contabilidade do sistema por meio do pacote *sysstat*.
- **LYNIS:** Atualização do binário da suíte Lynis para a versão suportada pelo repositório upstream, eliminando o aviso de versão legada.

6.3 Baixa Prioridade e Informativos

Controles que demandam monitoramento, automações incrementais ou tolerância operacional contínua:

- **LOGG-2190:** Monitoramento de ponteiros de arquivos deletados em execução por intermédio do utilitário *lsuf +L1*.
- **FIRE-4513:** Análise cadastral de regras de roteamento iptables/UFW para evitar descarte prematuro de fluxos destinados aos contêineres e aplicações.
- **FILE-7524:** Refinamento contínuo das permissões de acesso do sistema de arquivos para arquivos administrativos secundários.

- **BOOT-5264:** Implementação progressiva de diretivas de isolamento (sandboxing) nas unidades do systemd dos serviços instalados.
- **TOOL-5002:** Criação de rotinas centralizadas para execução periódica e automatizada dos relatórios da ferramenta Lynis.

7. Controles Deliberadamente Não Aplicados

Em consonância com as restrições arquiteturais do projeto, a estabilidade dos serviços de produção se sobrepôs à busca dogmática por pontuação em ferramentas de varredura. Os controles detalhados a seguir foram analisados e descartados de maneira intencional:

Controle / Diretiva	Restrição Operacional	Impacto Real se Executado	Decisão Técnica
Particionamento Separado (/home, /tmp, /var) — FILE-6310	Servidor bare-metal monolítico provisionado em disco único.	Necessidade de desmontagem completa, reparticionamento e indisponibilidade prolongada.	Descartado. Isolamento compensado via controles lógicos de permissão e cotas.
Desativação do Módulo usb-storage — USB-1000	Serviço Jellyfin utiliza unidades de disco rígido externas via barramento USB para mídias.	Inviabilização imediata da leitura e streaming do catálogo de entretenimento.	Descartado. Necessidade funcional comprovada.
Bloqueio de Carregamento de Módulos (kernel.modules_disabled)	Ambiente bare-metal sujeito a compilações e atualizações contínuas de pacotes.	Impossibilidade de compilar módulos pelo DKMS e bloqueio de novos hardwares.	Descartado. Manutenção da flexibilidade operacional do hardware.
Ocultação de Processos (hidepid=2 em /proc)	Ambiente executa o agente de métricas Performance Co-Pilot (pmcd, pmlogger).	Falha na coleta de telemetria sistêmica por impedimento de leitura dos processos.	Descartado. Preservação do sistema de observabilidade corporativa.
Ativação Estrita de Secure Boot em Firmware	Hardware headless gerenciado remotamente sem interface visual dedicada instalada.	Risco de interrupção da sequência de inicialização em falhas de assinatura digital.	Descartado. Acesso físico limitado ao dispositivo em caso de falha de boot.
Diretiva noexec na Partição /dev/shm	Processos da pilha LAMP, MariaDB e binários compilados em memória dinâmica.	Instabilidade, falhas de execução de threads e quebra no funcionamento do PHP/Apache.	Descartado. Requisito de execução compartilhado por daemons do servidor.
Restrição Rígida de Compiladores — HRDN-7222	Compiladores GCC/Make necessários para manutenção e módulos dinâmicos do kernel.	Quebra imediata de rotinas automatizadas de atualização de drivers de periféricos.	Descartado. Uso restrito mitigado por permissões de execução locais.

Expurgo de Contas Bloqueadas — AUTH-9284	Contas marcadas como bloqueadas pertencem a usuários de sistema (mysql, jellyfin).	Interrupção operacional ou falha de inicialização de múltiplos daemons locais.	Descartado. Contas sem shell interativo mantidas intocadas.
--	--	--	---

8. Lições Aprendidas

O processo de aplicação dos princípios de cibersegurança defensiva em infraestruturas ativas propiciou a validação de lições técnicas relevantes para a governança do servidor:

- **Segurança Não Deve Comprometer a Operação:** O processo de hardening em ambientes produtivos exige a catalogação prévia de todas as dependências de processos. Tratar relatórios de auditoria automatizados como comandos imperativos resulta invariavelmente na indisponibilidade dos serviços.
- **Falhas Silenciosas em Componentes de Defesa:** Durante o levantamento da pilha defensiva, identificou-se que o framework **Fail2ban** apresentava duas jails ativas (*nextcloud* e *pihole-dns*) apontando para arquivos de filtros inexistentes na pasta *filter.d*. A ferramenta continuava operacional, mas sem executar o bloqueio efetivo das referidas rotas. A verificação manual dos logs foi indispensável para sanar a inconsistência.
- **Validação Segura de Mecanismos de Acesso:** A adoção estrita da verificação sintática de arquivos de configuração (*sshd -t*) associada à persistência de uma sessão SSH primária estabelecida atuou como salvaguarda eficaz contra isolamento involuntário do operador em um servidor headless.
- **Gradualismo Defensivo:** Ganhos consistentes de proteção podem ser consolidados com intervenções de baixo risco sistêmico (como ajustes em *sysctl*, regras de *auditd* e expiração de senhas humanas), postergando modificações que exigem reengenharia de arquitetura para janelas programadas.

9. Conclusão e Próximos Passos

O projeto atingiu seu objetivo primário de estabelecer um patamar defensivo superior no nó **plmnsrv**, elevando o indicador do sistema para **80 pontos** e zerando todas as vulnerabilidades catalogadas como críticas pelo motor da auditoria. A integridade estrutural, a comunicação do proxy Caddy, o gerenciamento de registros do Pi-Hole e a disponibilidade das aplicações Nextcloud e Jellyfin foram mantidas em sua totalidade ao longo de todo o procedimento de modificação.

Como roteiro de sustentação para a evolução contínua da governança do servidor, definem-se as seguintes etapas:

4. Executar as ações pontuais de baixa complexidade mapeadas como prioridade alta (saneamento do arquivo */etc/hosts*, atualização de banners institucionais e parametrização dos hashes SHA do AIDE).
5. Executar a limpeza das bibliotecas de pacotes declaradas órfãs e a remoção das versões legadas de imagens do kernel através do gerenciador APT.
6. Instituir uma rotina mensal automatizada para execução do auditor Lynis, armazenando os resultados históricos para fins de análise de conformidade e mitigação de drifts de configuração.
7. Planejar a segregação de registros de log via host syslog dedicado em fase futura de expansão da infraestrutura local, atendendo integralmente ao controle de armazenamento externo.